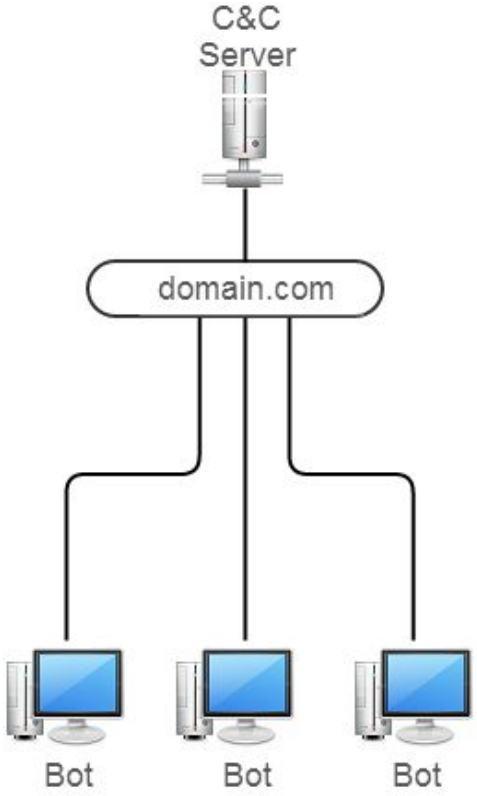
Botnets & Worms

ECE 239AS

Liz Izhikevich

Botnets (Mirai)

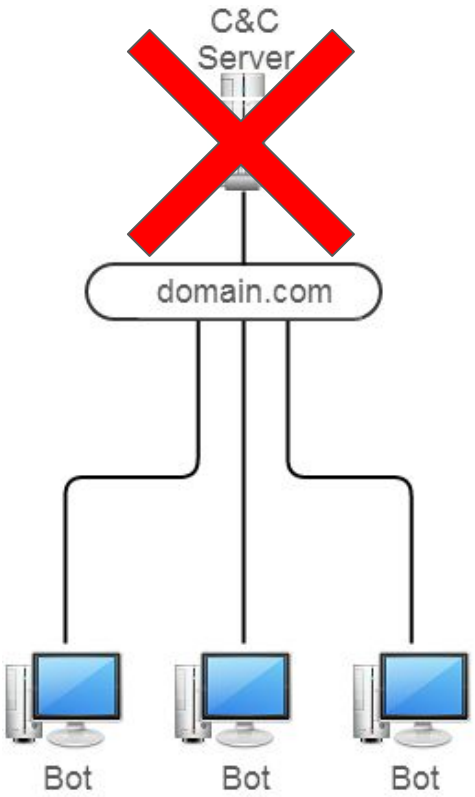
C&C Botnet Anatomy



- Centralized “command and control” (C&C) server that instructs the bots what to do
- C&C server will likely have multiple domains that the bots can reach it over
  - Complicates the process of shutting down botnet: need to take down all domains, can’t just take down the actual server
- C&C server will likely be hosted on a “bulletproof” server

Taking down C&C botnets

- Take control of C&C server
- Issue remediation commands to compromised devices as if C&C had issued them
- Bots think they're taking orders from C&C and clear out the malware



Understanding the Mirai Botnet

Manos Antonakakis[†], Tim April[◆], Michael Bailey[★], Matthew Bernhard[‡], Elie Bursztein[✳]
Jaime Cochran[△], Zakir Durumeric[‡], J. Alex Halderman[‡], Luca Invernizzi[✳]
Michalis Kallitsis[•], Deepak Kumar[★], Chaz Lever[†], **Zane Ma**[★], Joshua Mason[★]
Damian Menscher[✳], Chad Seaman[◆], Nick Sullivan[△], Kurt Thomas[✳], Yi Zhou[★]

[◆] *Akamai Technologies,* [△] *Cloudflare,* [†] *Georgia Institute of Technology,* [✳] *Google,* [•] *Merit Network*
[★] ***University of Illinois Urbana-Champaign***, [‡] *University of Michigan*

Mirai

THE WALL STREET JOURNAL.

Cyberattack Knocks Out Access to Websites

reddit

amazon web services™

NETFLIX

Spotify

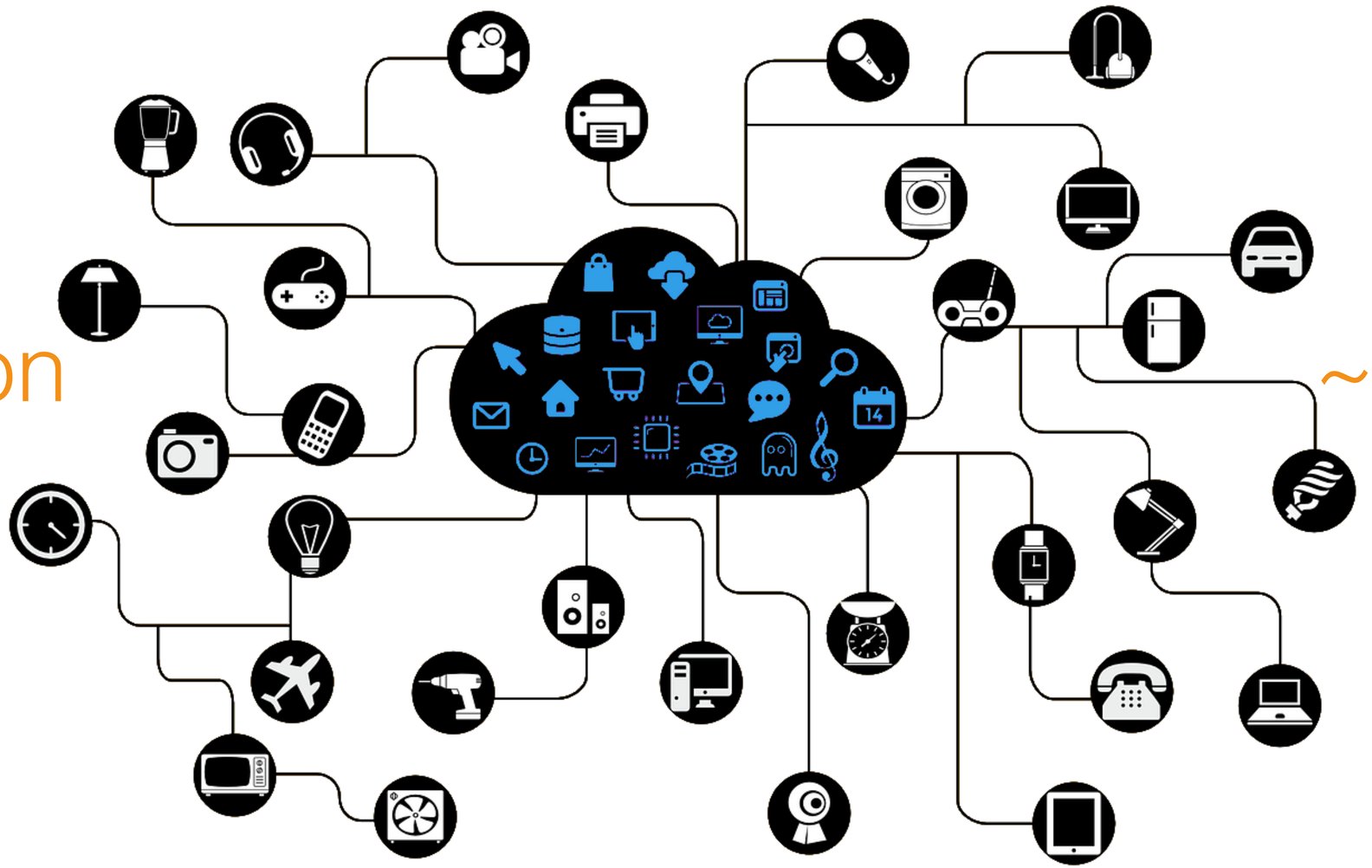
twitter

GitHub

PayPal

Growing IoT Threat

2016
6 - 9 Billion



2020
~30 Billion

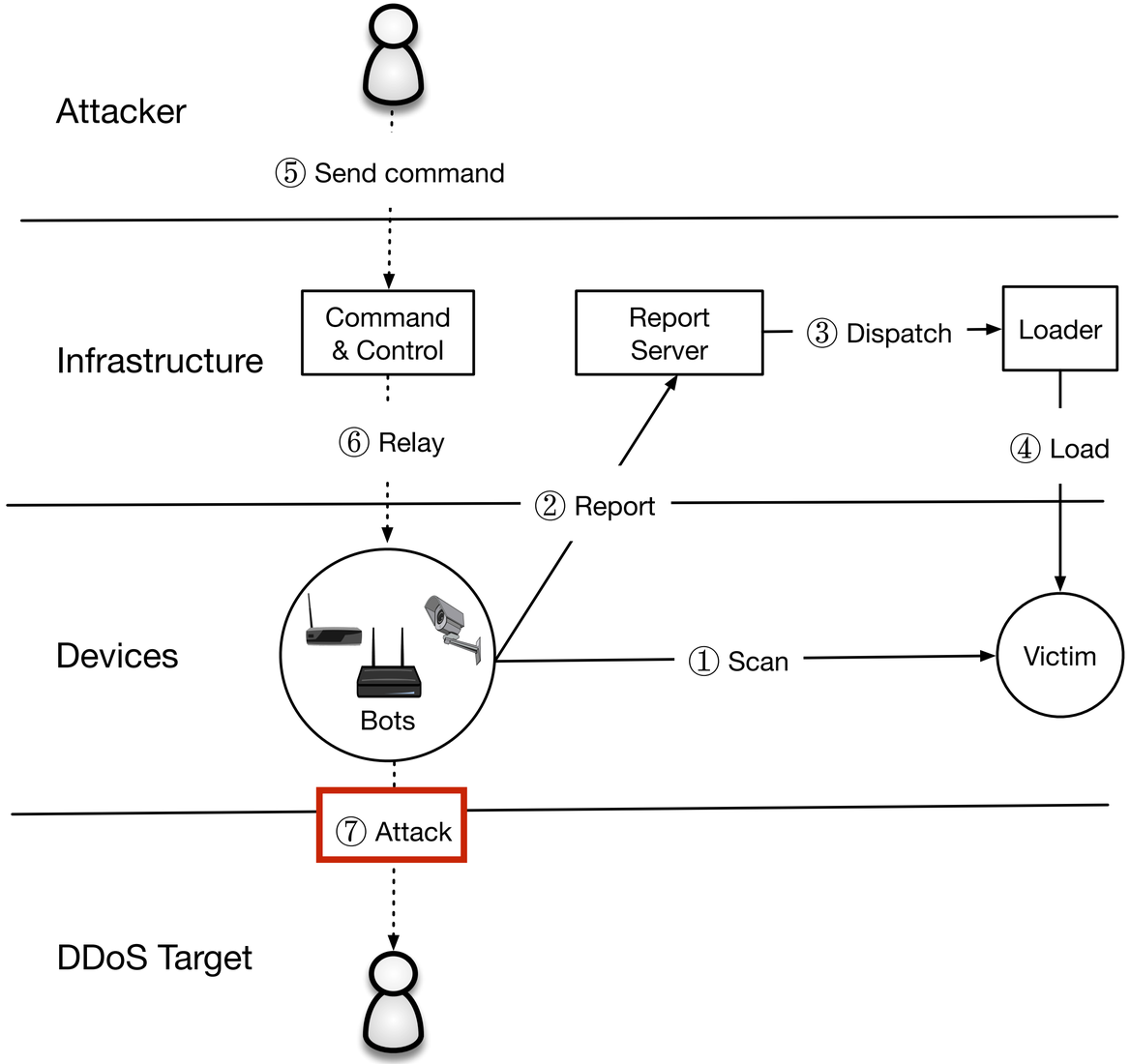
Research Goals

Snapshot the IoT botnet phenomenon

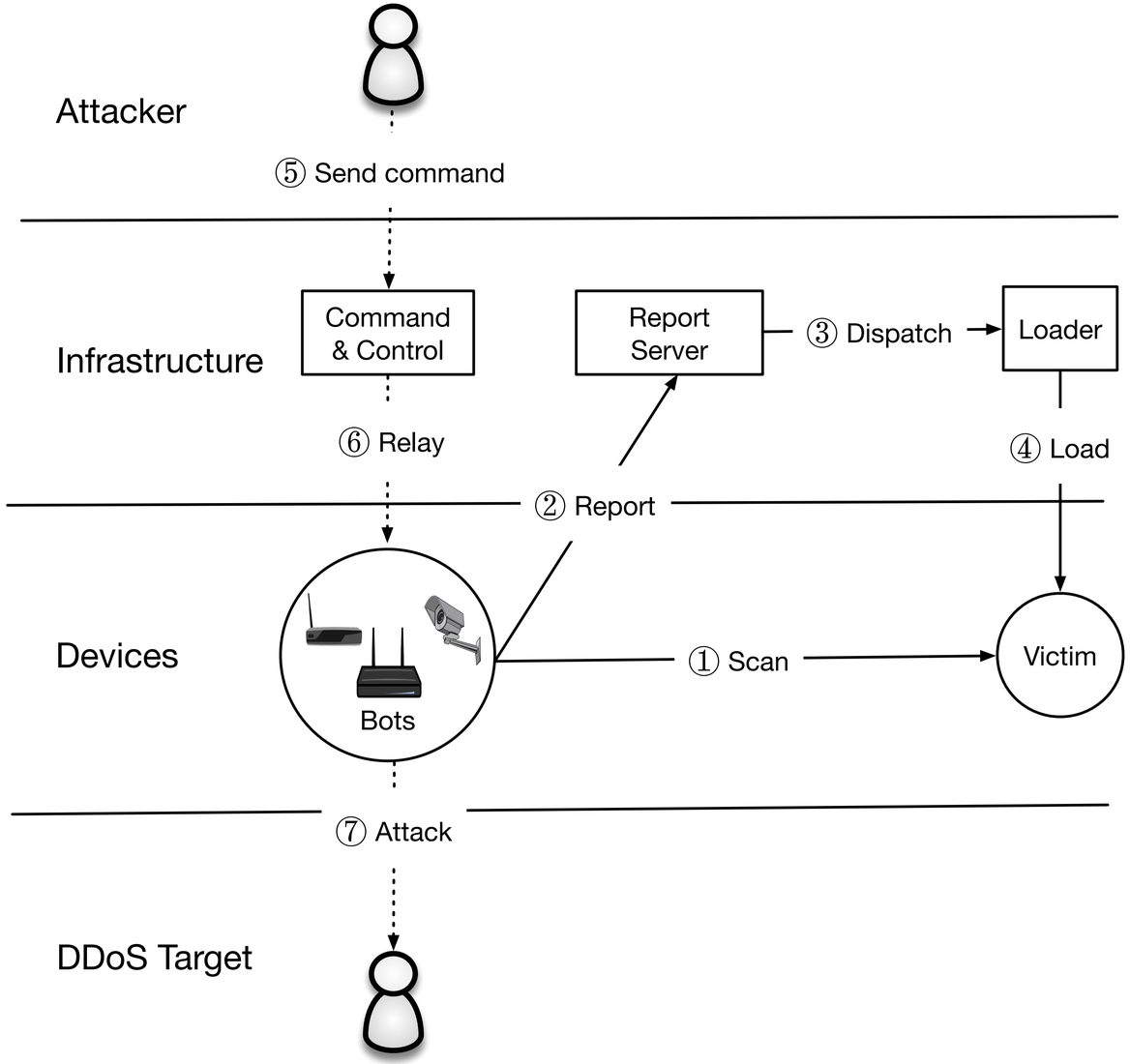
Reconcile a broad spectrum of botnet data perspectives

Understand Mirai's mechanisms and motives

Lifecycle


Attacker
⑤ Send command
Infrastructure
Command & Control
Report Server
③ Dispatch
Loader
⑥ Relay
④ Load
② Report
Devices
Bots
① Scan
Victim
⑦ Attack
DDoS Target

Measurement

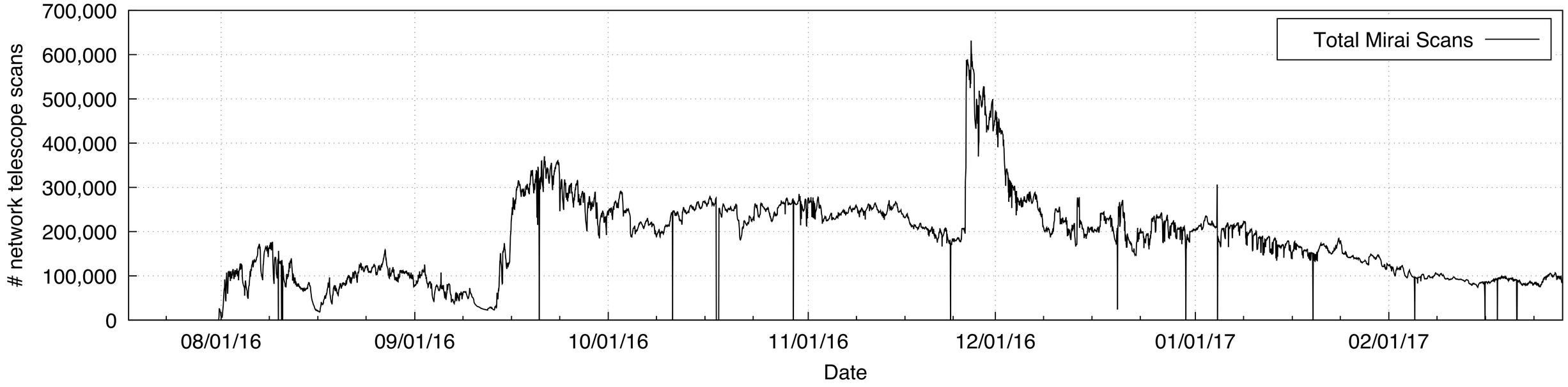


Data Source	Size
Network Telescope	4.7M unused IPs
Active Scanning	136 IPv4 scans
Telnet Honeypots	434 binaries
Malware Repository	594 binaries
Active/Passive DNS	499M daily RRs
C2 Milkers	64K issued attacks
Krebs DDoS Attack	170K attacker IPs
Dyn DDoS Attack	108K attacker IPS

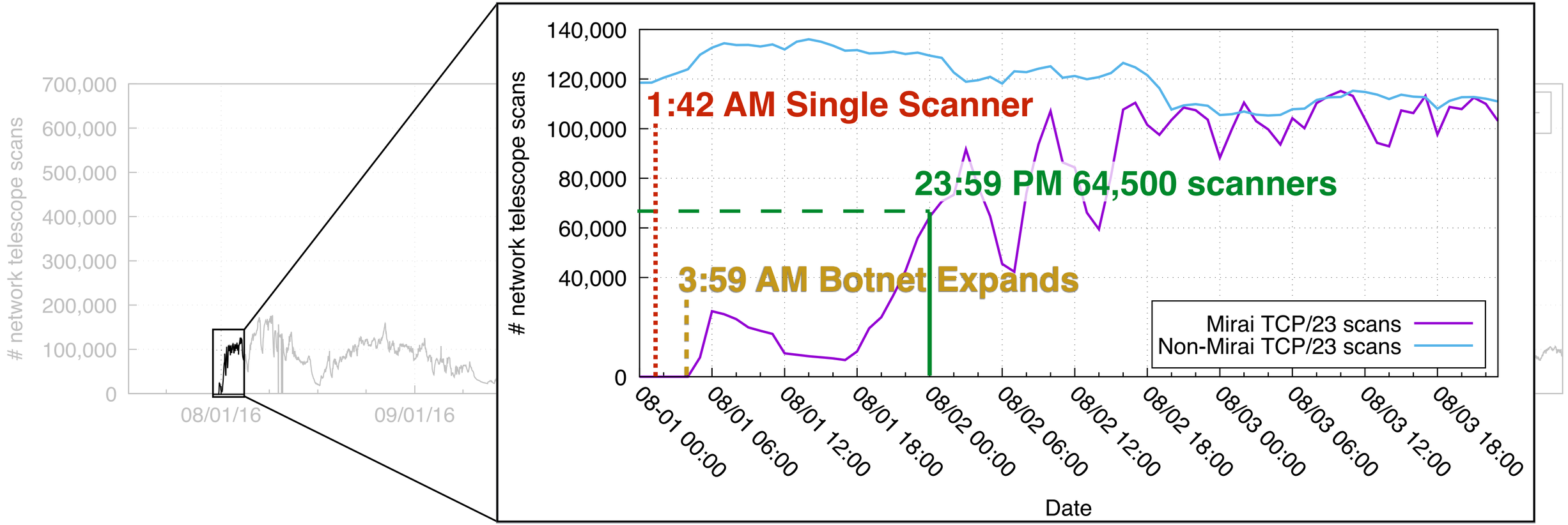
July 2016 - February 2017

What is the Mirai botnet?

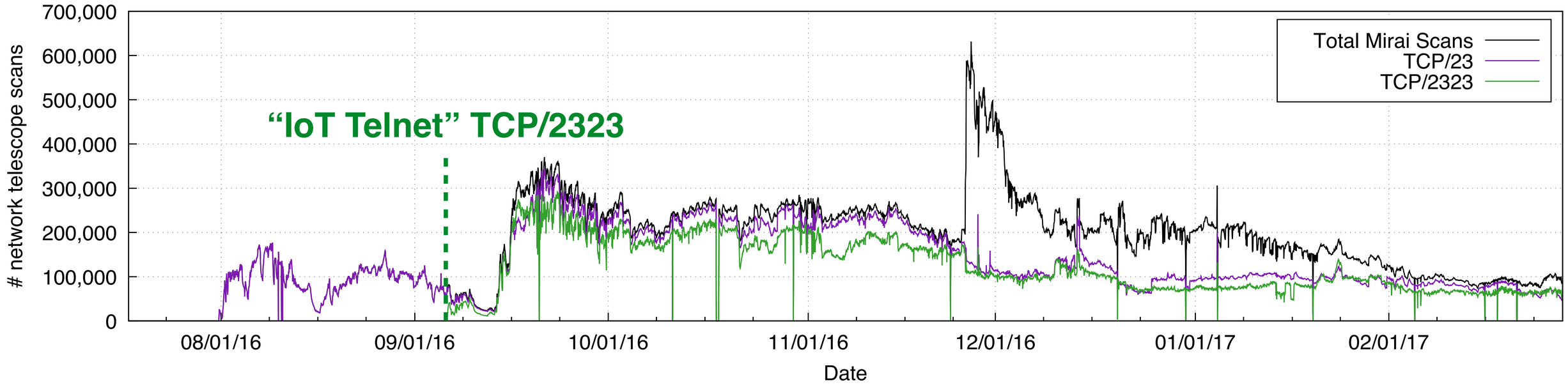
Population


700,000
600,000
500,000
400,000
300,000
200,000
100,000
0
network telescope scans
Total Mirai Scans
08/01/16
09/01/16
10/01/16
11/01/16
12/01/16
01/01/17
02/01/17
Date

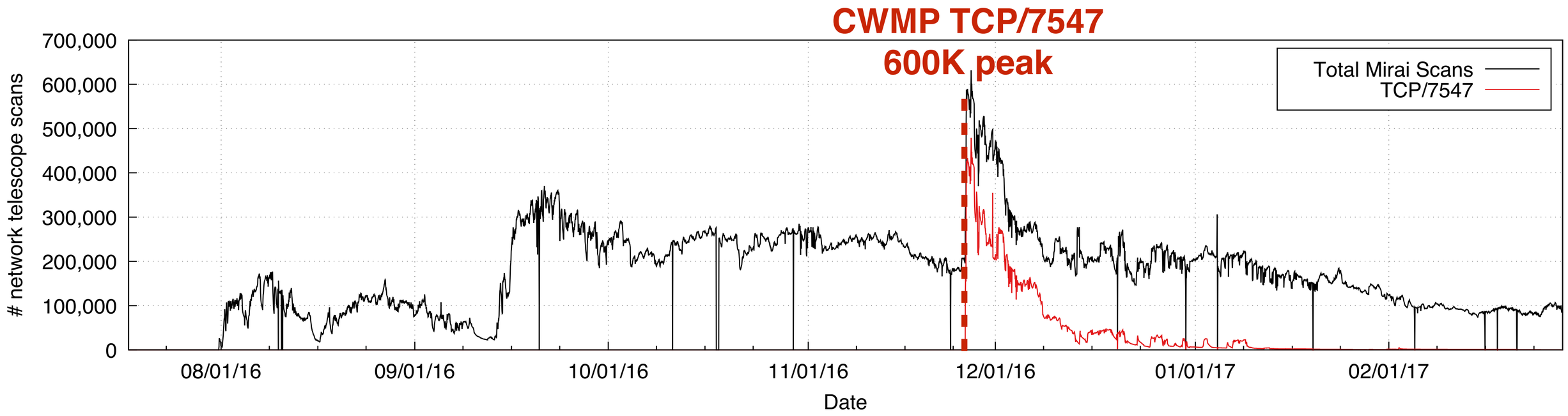
Rapid Emergence



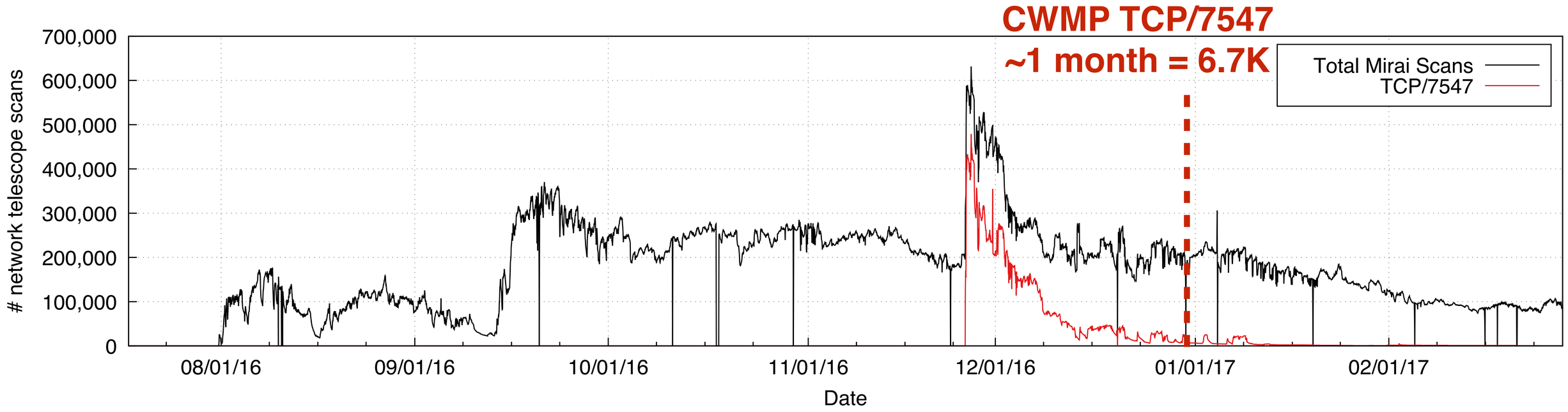
Many Ports of Entry



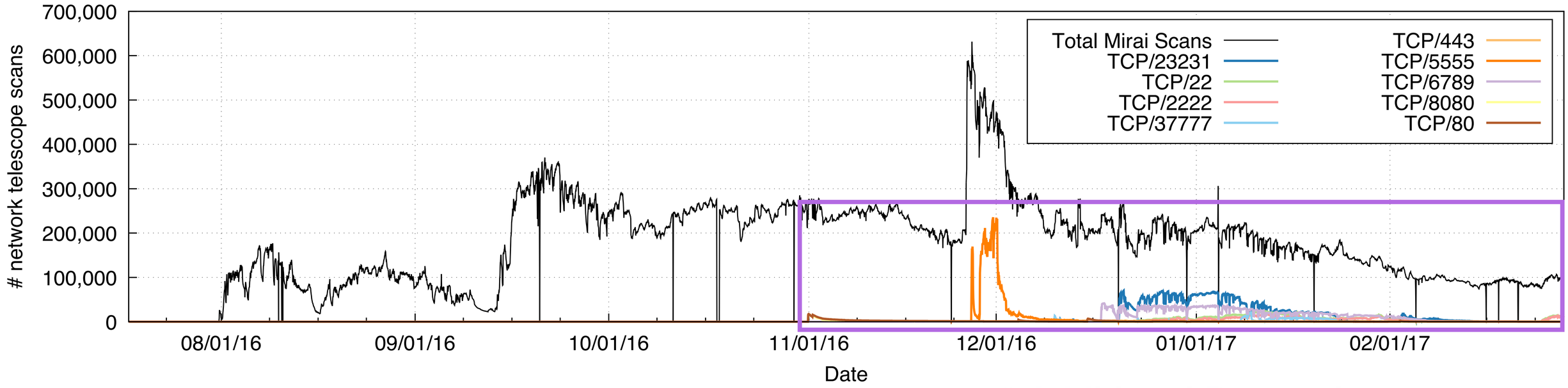
Many Ports of Entry



Many Ports of Entry

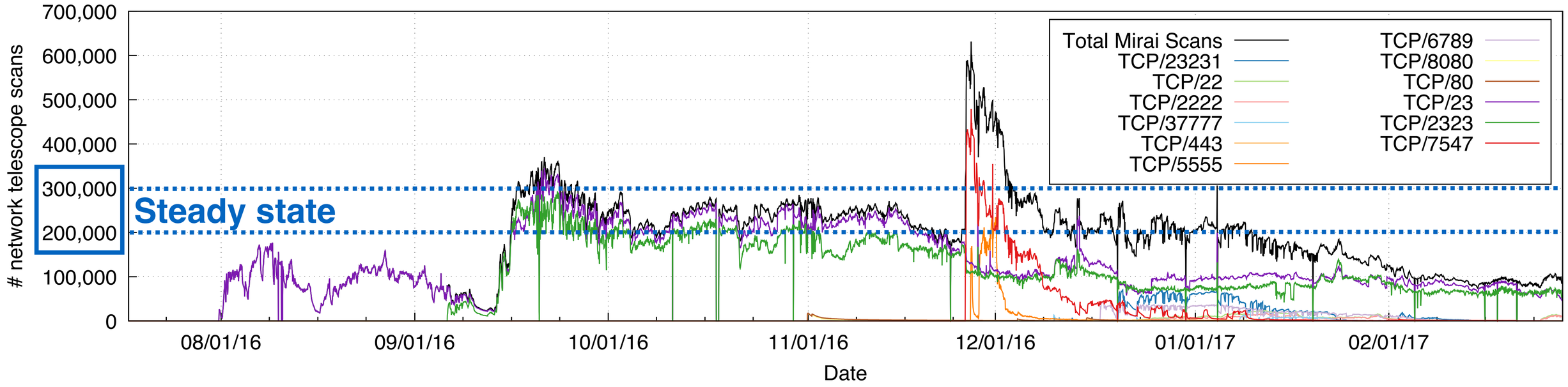


Many Ports of Entry

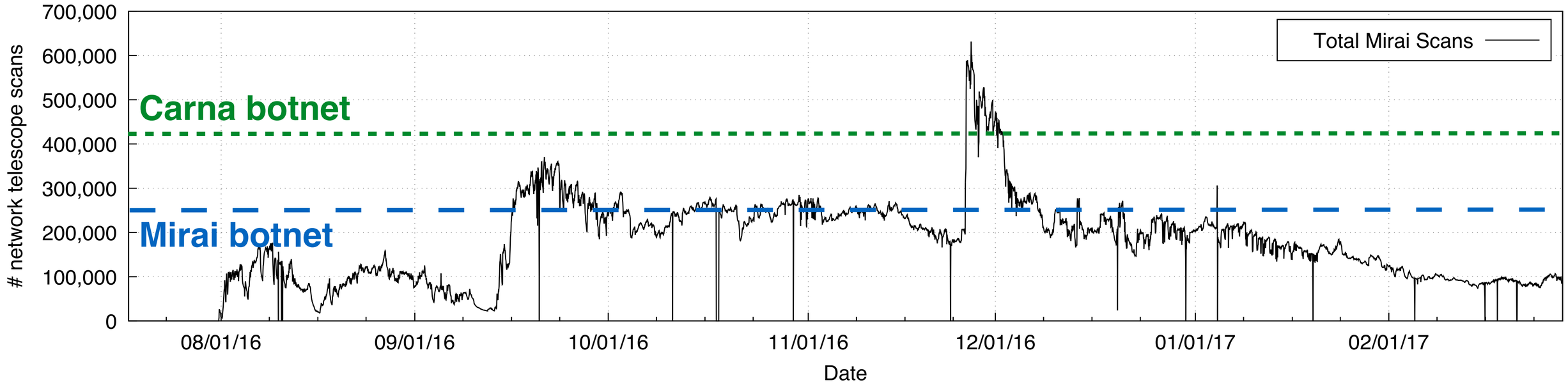


9 Additional Protocols

200K-300K Mirai Bots



Modest Mirai

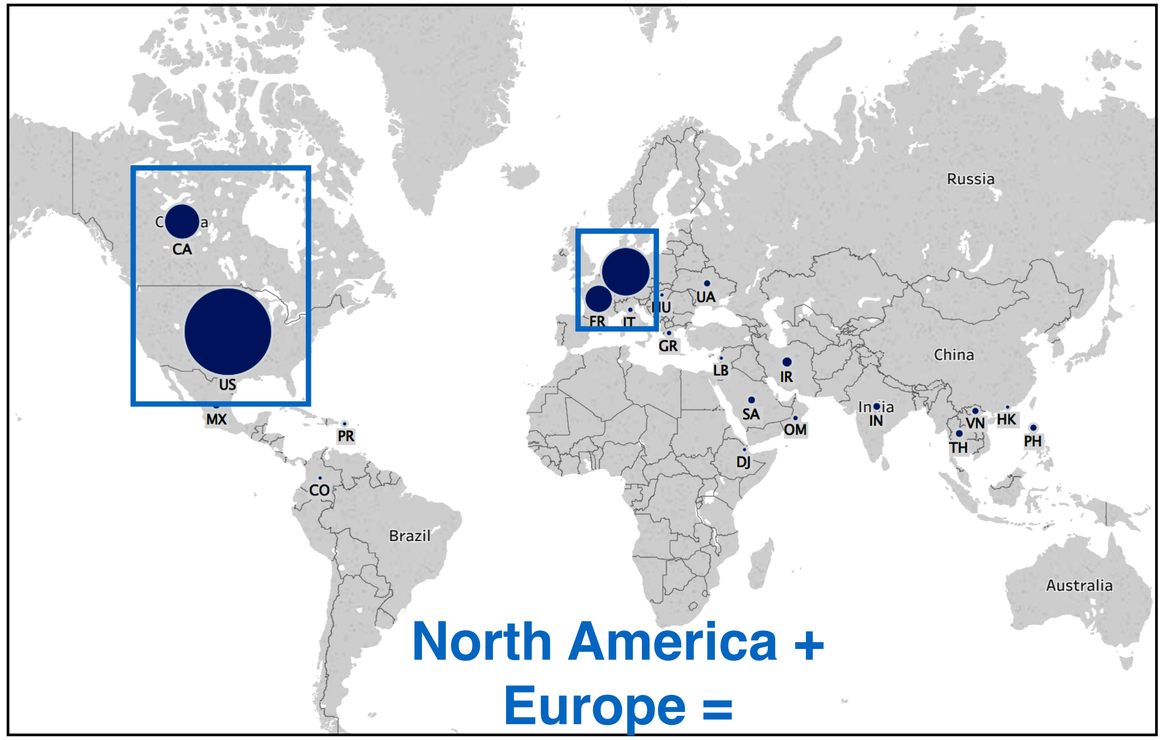


Global Mirai

Mirai

South America + Southeast Asia = 50% of Infections

TDSS/TDL4



North America + Europe = 94% of Infections

Cameras, DVRs, Routers

Targeted Devices

Source Code Password List

Device Type	# Targeted Passwords	Examples
Camera / DVR	26 (57%)	dreambox, 666666
Router	4 (9%)	smcadmin, zte521
Printer	2 (4%)	00000000, 1111
VOIP Phone	1 (2%)	54321
Unknown	13 (28%)	password, default

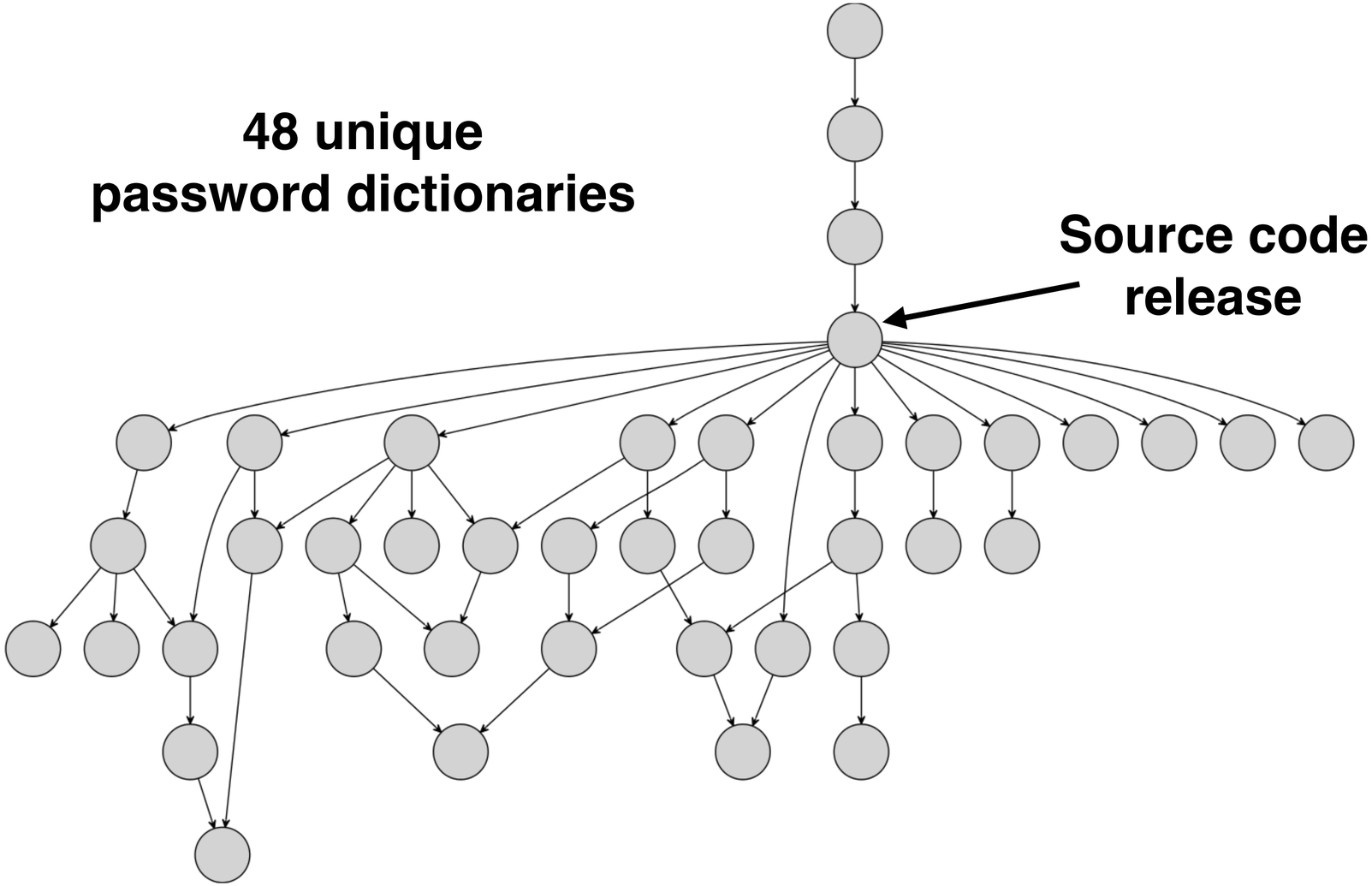
Infected Devices

HTTPS banners

Device Type	# HTTPS banners
Camera / DVR	36.8%
Router	6.3%
NAS	0.2%
Firewall	0.1%
Other	0.2%
Unknown	56.4%

Who ran Mirai?

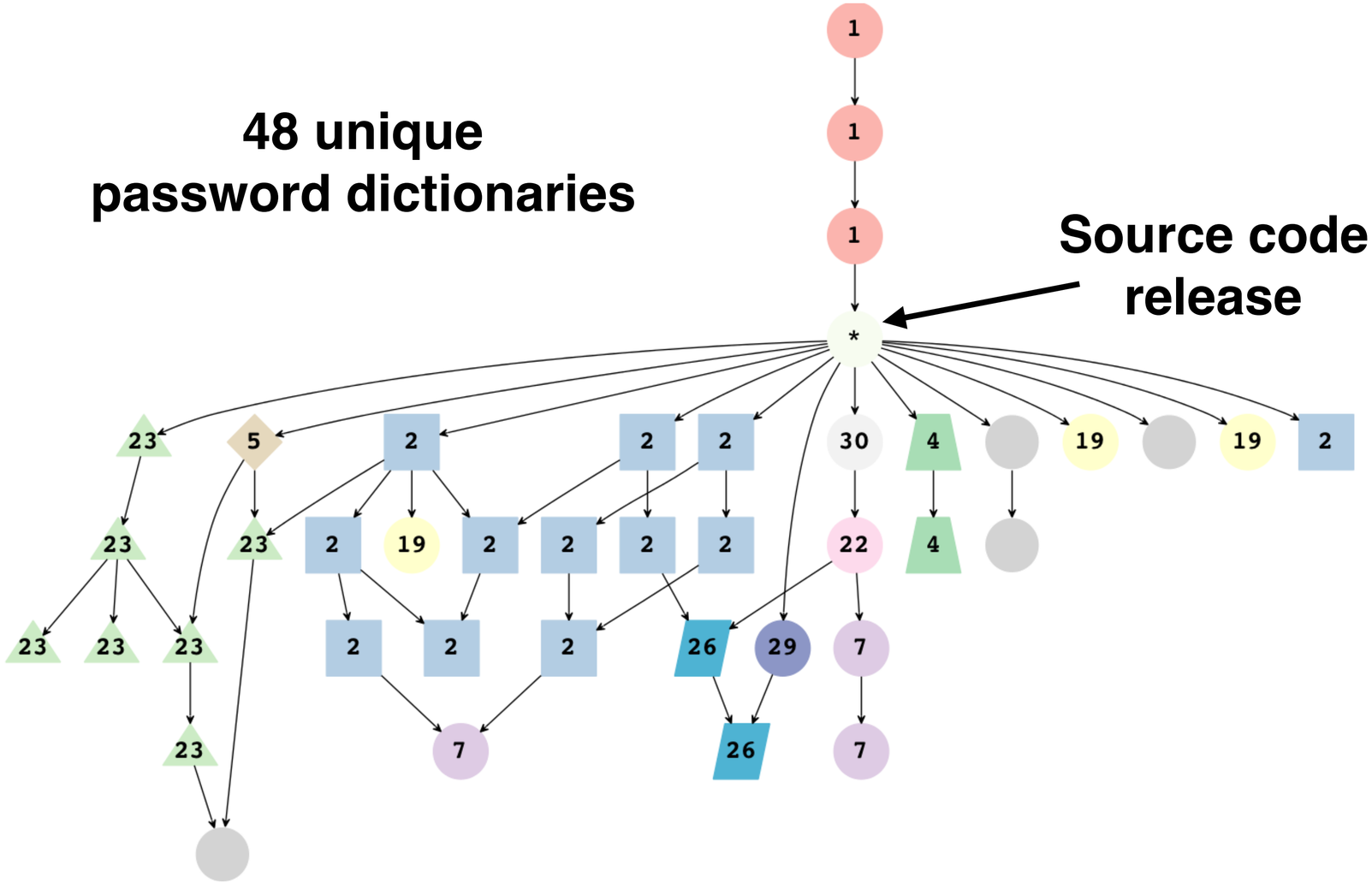
Divergent Evolution



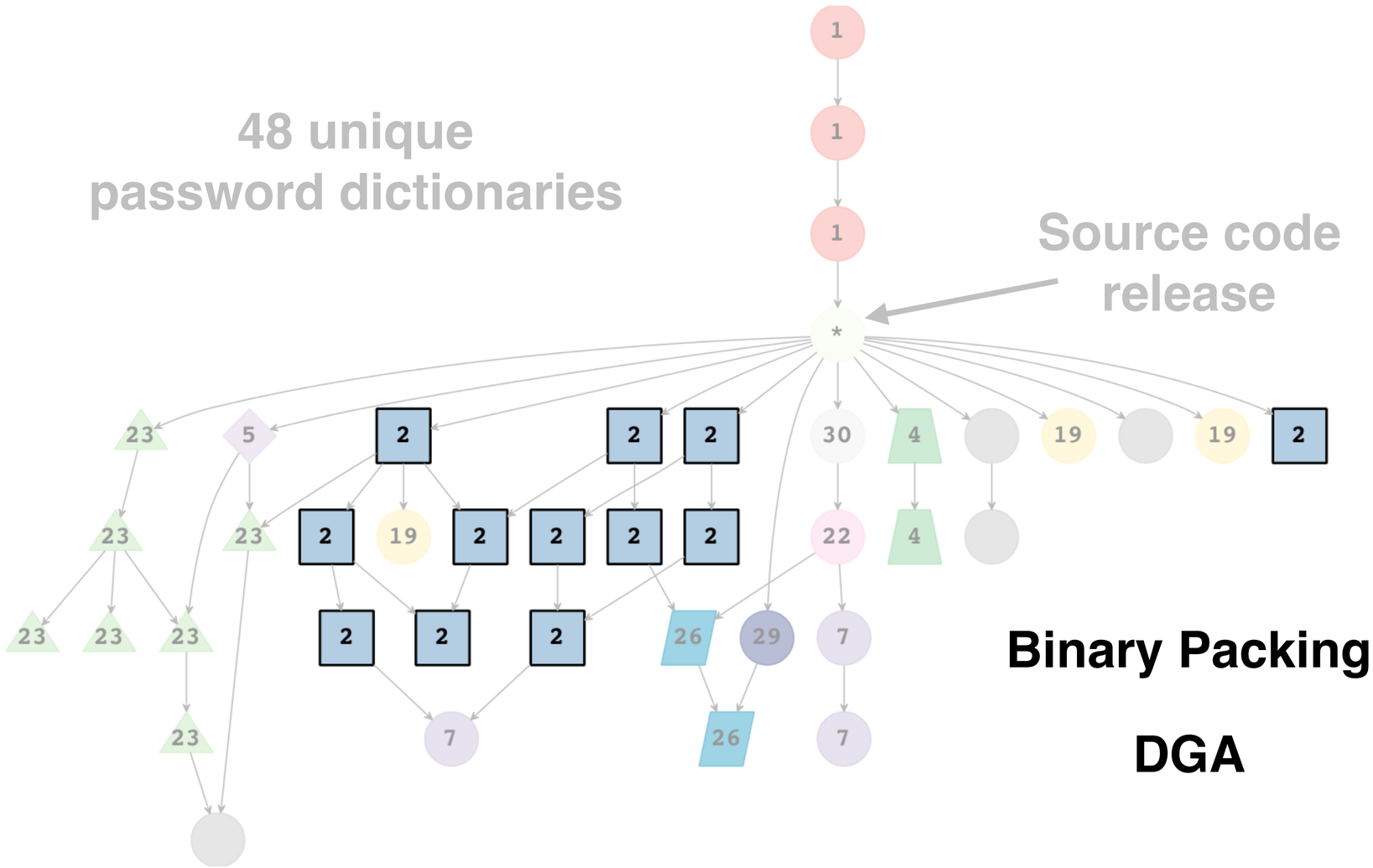
Divergent Evolution

48 unique password dictionaries

Source code release



Divergent Evolution



How was Mirai used?

KrebsOnSecurity

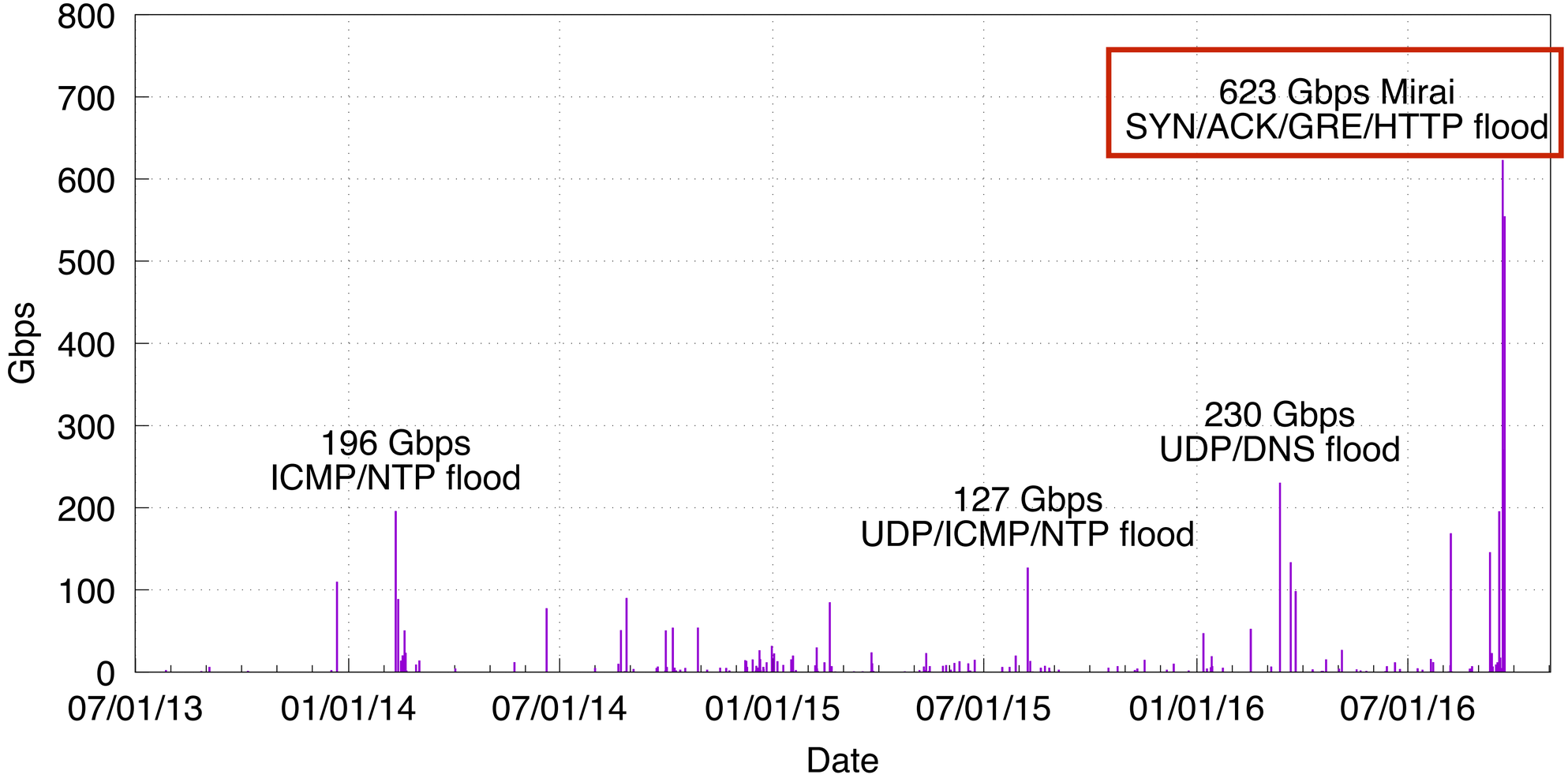
KrebsonSecurity
In-depth security news and investigation

21 **KrebsOnSecurity Hit With Record DDoS**
SEP 16

Akamai

Project Shield

Largest Reported DDoS



Dyn Attacker Motives

The New York Times

"It is possible, investigators say, that the attack on Dyn was conducted by a criminal group that wanted to extort the company. Or it could have been done by "hacktivists." Or a foreign power that wanted to remind the United States of its vulnerability."

Dyn Attacker Motives

The New York Times

"It is possible, investigators say, that the attack on Dyn was conducted by a criminal group that wanted to extort the company. Or it could have been done by "hacktivists." Or a foreign power that wanted to remind the United States of its vulnerability."

Targeted IP	rDNS	Passive DNS
208.78.70.5	ns1.p05.dynect.net	**ns00.playstation.net**
204.13.250.5	ns2.p05.dynect.net	**ns01.playstation.net**
208.78.71.5	ns3.p05.dynect.net	**ns02.playstation.net**
204.13.251.5	ns4.p05.dynect.net	**ns03.playstation.net**
198.107.156.219	service.playstation.net	**ns05.playstation.net**
216.115.91.57	service.playstation.net	**ns06.playstation.net**

- Top targets are linked to Sony PlayStation
- Attacks on Dyn interspersed among attacks on other game services

Booter-like Targets

Games: Minecraft, Runescape, game commerce site

Politics: Chinese political dissidents, regional Italian politician

Anti-DDoS: DDoS protection service

Misc: Russian cooking blog

Overview

200,000 - 300,000 globally distributed IoT devices compromised by default Telnet credentials

Evidence of **multiple operators** releasing new strains of Mirai

Mirai follows a **booter-like** pattern of behavior that is capable of launching some of the **largest attacks on record**

New Dog, Old Tricks

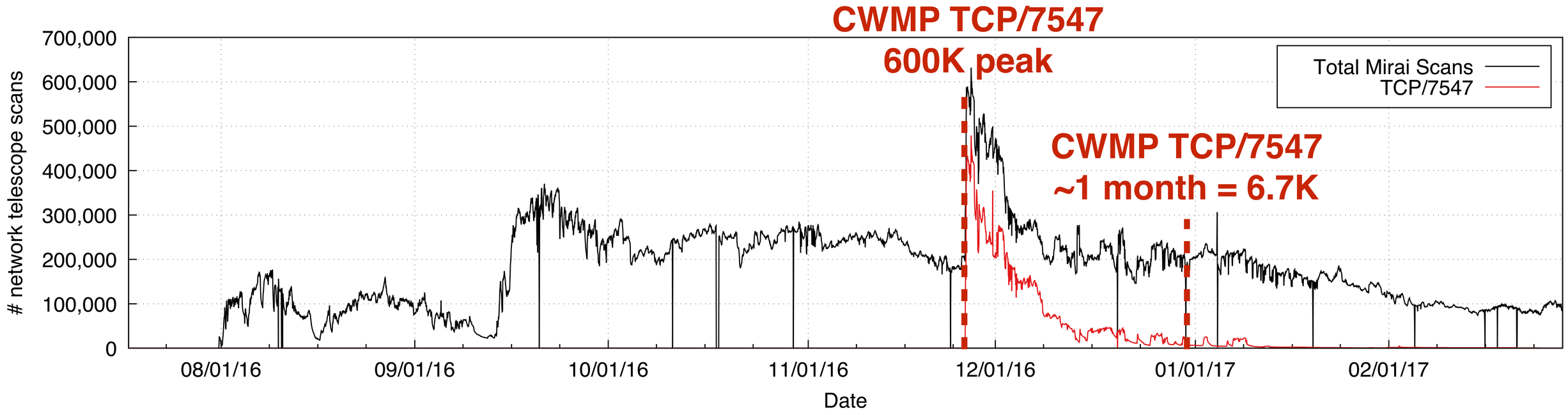
Security Hardening

Username	Password
root	xc3511
root	vizxv
root	admin
admin	admin
root	888888
root	xmhdipc
root	default
root	juantech
root	123456
root	54321
support	support
root	(none)
admin	password
root	root
root	12345
user	user
admin	(none)
root	pass
admin	admin1234
root	1111
admin	smcadmin

Username	Password
admin	1111
root	666666
root	password
root	1234
root	klv123
Administrator	admin
service	service
supervisor	supervisor
guest	guest
guest	12345
guest	12345
admin1	password
administrator	1234
666666	666666
888888	888888
ubnt	ubnt
root	klv1234
root	Zte521
root	hi3518
root	jvbzd
root	anko

Username	Password
root	zlxx.
root	7ujMko0vizxv
root	7ujMko0admin
root	system
root	ikwb
root	dreambox
root	user
root	realtek
root	0
admin	1111111
admin	1234
admin	12345
admin	54321
admin	123456
admin	7ujMko0admin
admin	1234
admin	pass
admin	meinsm
tech	tech
mother	fucker

Automatic Updates



Device Attribution

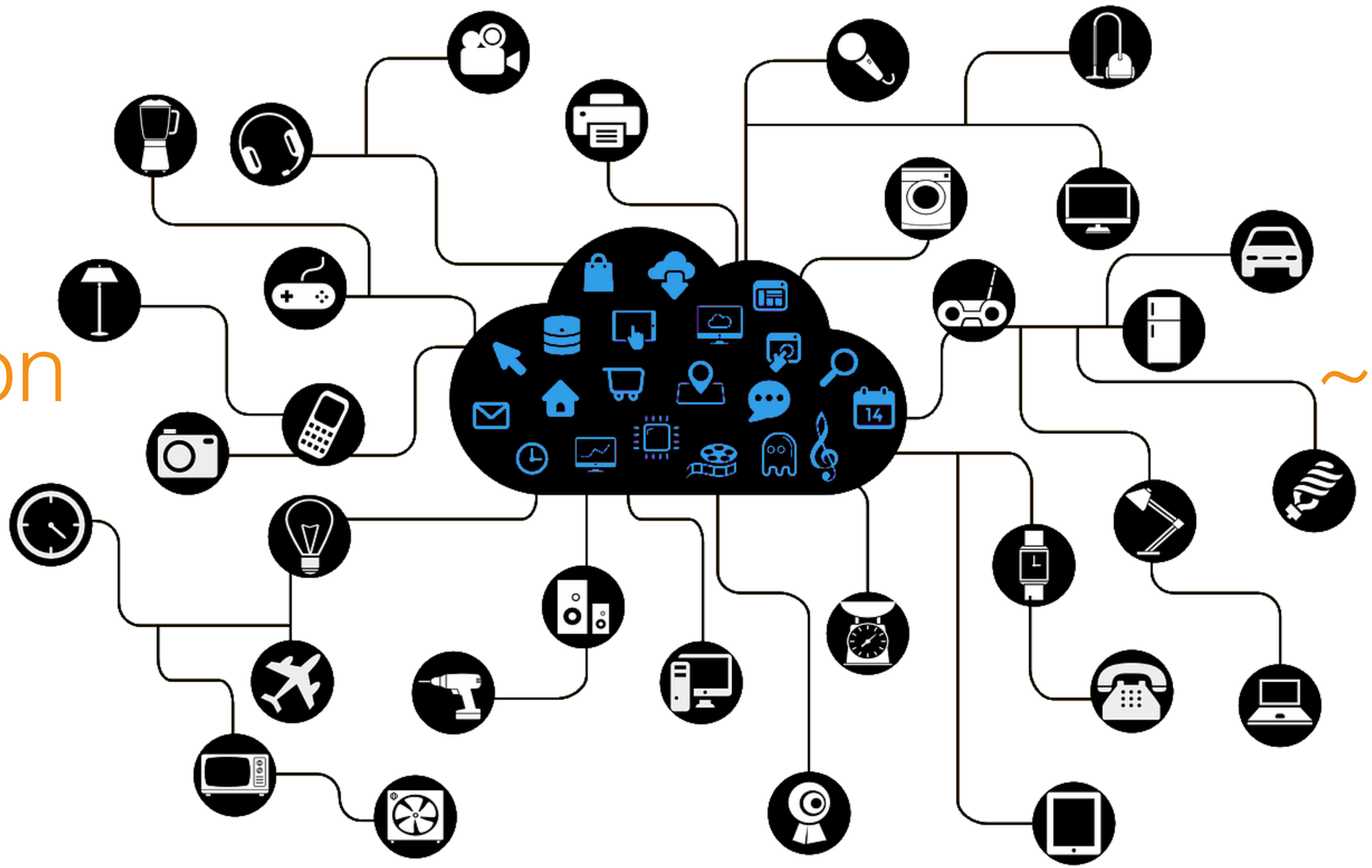
55.4M Scanning IP addresses

1.8M Protocol Banners

587K Identifying Labels

End-of-life

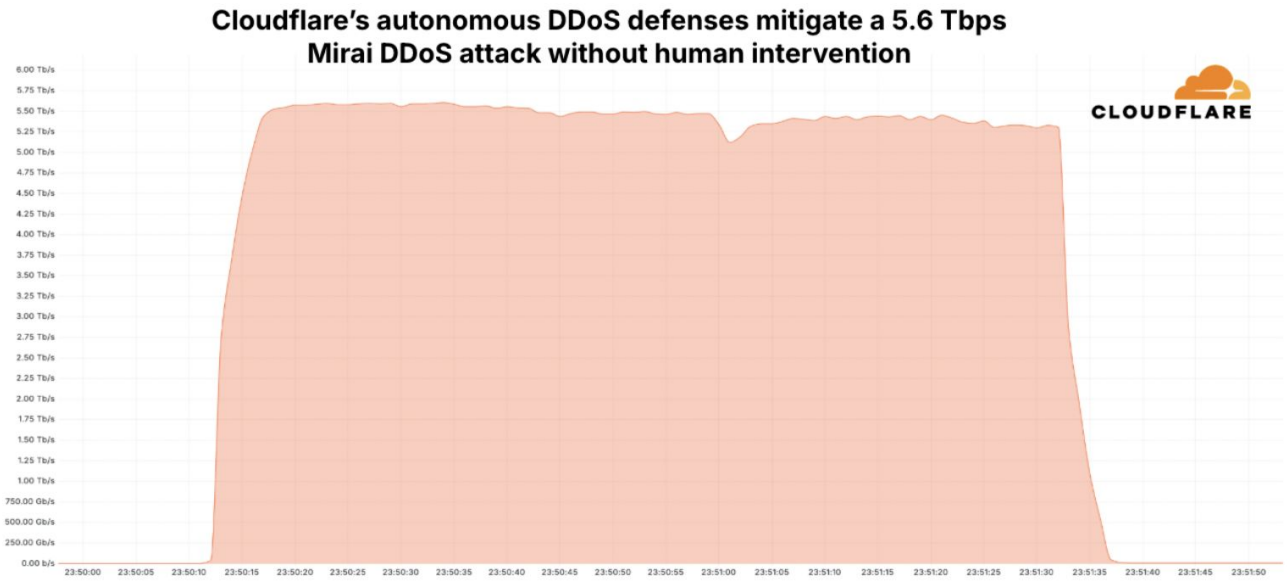
2016
6 - 9 Billion



2020
~30 Billion

Mirai is still active

October 2024: Largest DDoS attack on record caused by Mirai variant



https://blog.cloudflare.com/ddos-threat-report-for-2024-q4/#the-largest-ddos-attack-on-record

Taking down C&C botnets

- Botnet run by Russian military hacking group Fancy Bear
- Commodity malware “Moobot” repurposed to log in to routers with default admin passwords
  - Moobot is a Mirai variant… it haunts us still
- February 2024: FBI takedown

Office of Public Affairs
U.S. Department of Justice

Our Offices | Find Help | Contact Us

Search

About | News | Documents | Internships | FOIA | Contact | Information for Journalists

Justice.gov > Office of Public Affairs > News > Press Releases > Justice Department Conducts Court-Authorized Disruption of Botnet Controlled By The Russian Federation's Main Intelligence Directorate of The General Staff (GRU)

News

- All News
- Blogs
- Photo Galleries
- Podcasts
- Press Releases
- Speeches

PRESS RELEASE

Justice Department Conducts Court-Authorized Disruption of Botnet Controlled by the Russian Federation’s Main Intelligence Directorate of the General Staff (GRU)

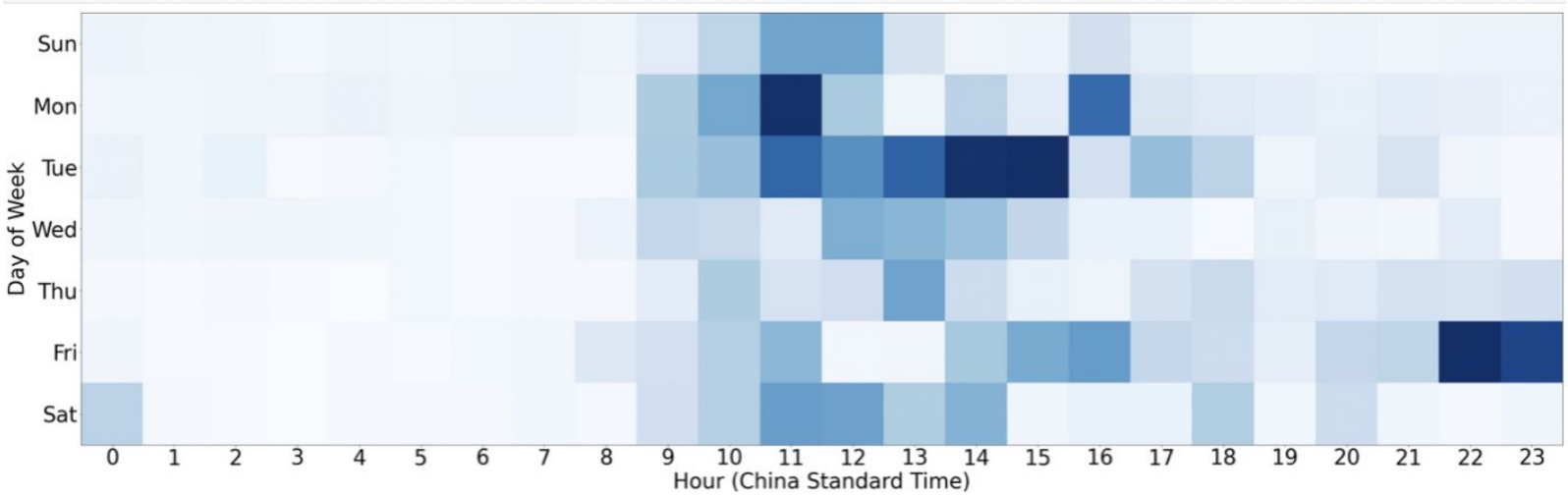
Thursday, February 15, 2024

For Immediate Release

Taking down C&C botnets

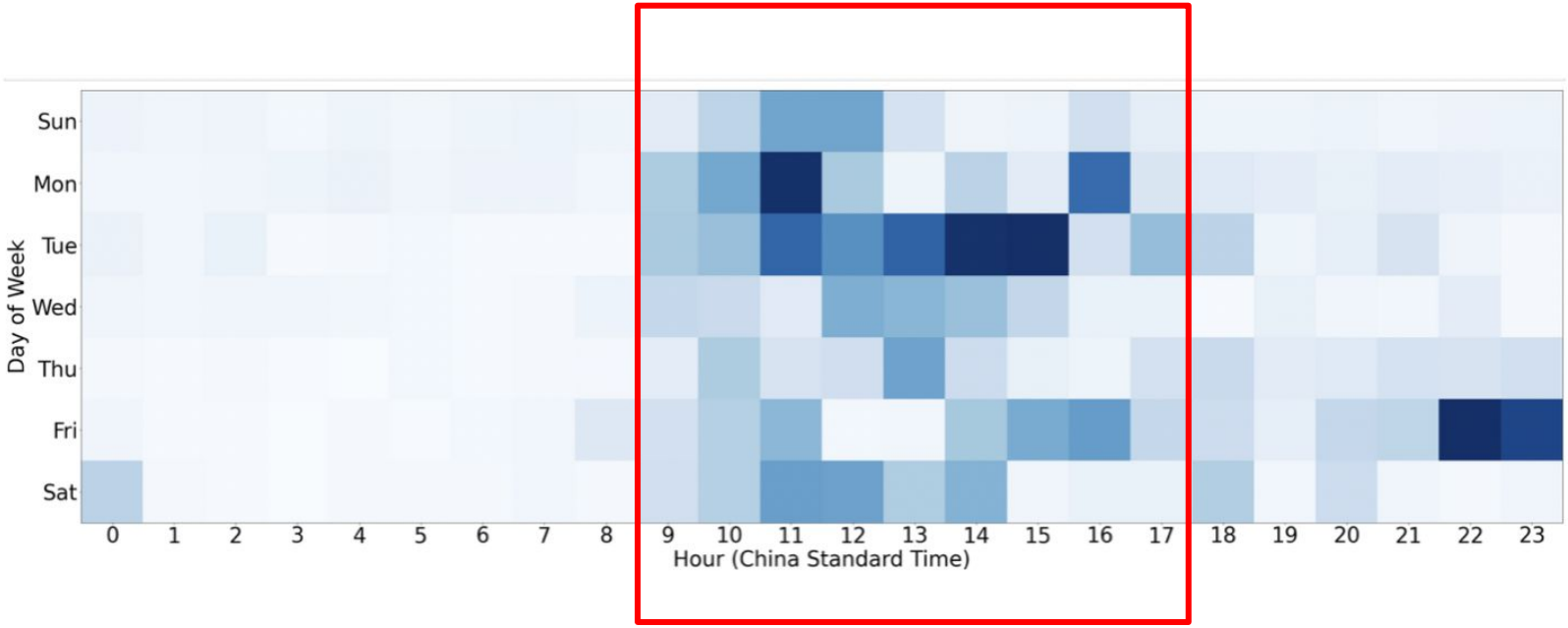
- “KV Botnet” run by Chinese state-sponsored hacking group Volt Typhoon
- Provided cover for group working to infiltrate US critical infrastructure
- Botnet targeted vulnerable end-of-life routers
- January 2024: FBI takedown

Sidenote: State-sponsored hacker working hours



Source:
https://blog.lumen.com/routers-roasting-on-an-open-firewall-the-kv-botnet-investigation/

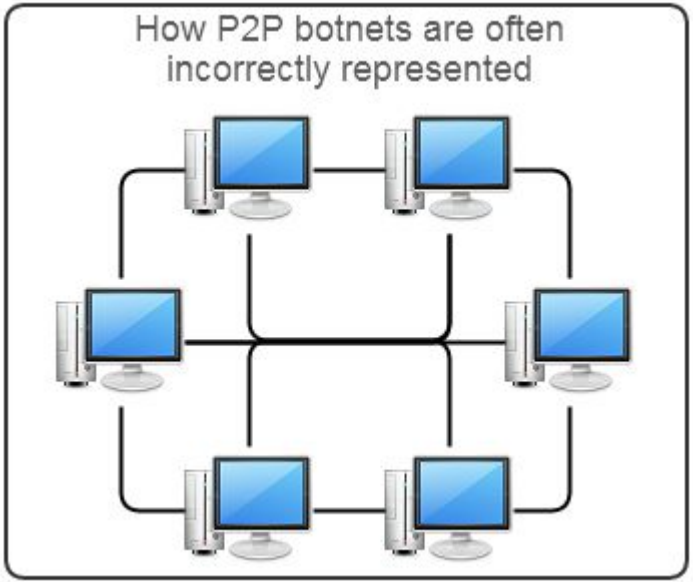
Sidenote: State-sponsored hacker working hours



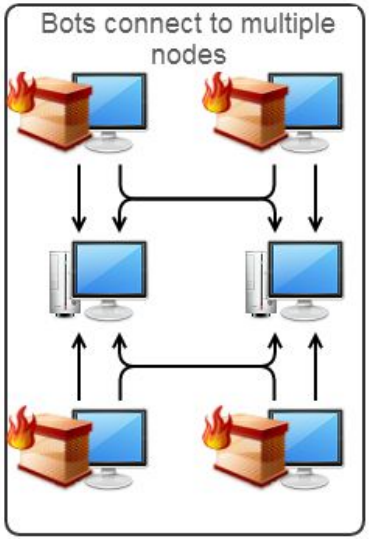
They're working a 9-5 job!

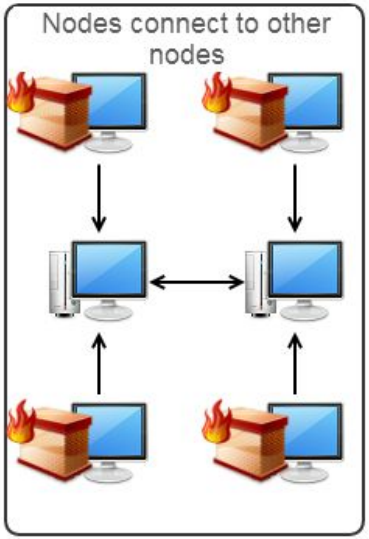
Source: https://blog.lumen.com/routers-roasting-on-an-open-firewall-the-kv-botnet-investigation/

Peer2Peer Botnet Anatomy



Peer2Peer Botnet Anatomy

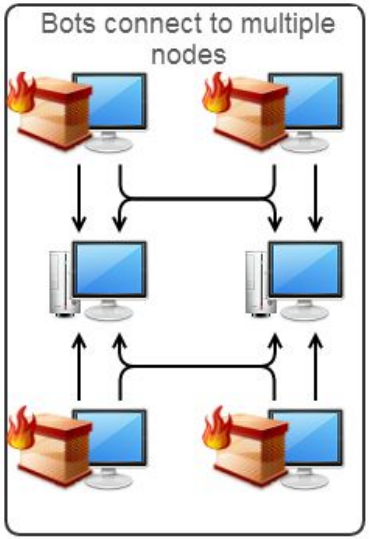


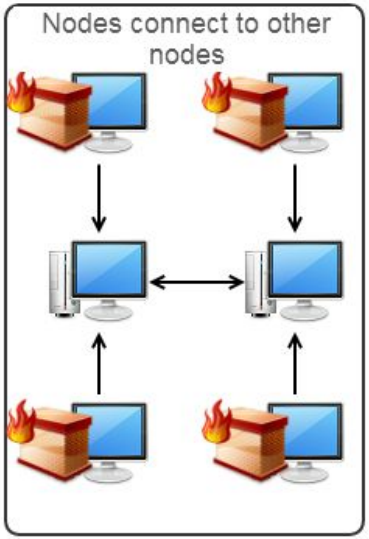


- "**Nodes/Peers**": Servers that are able to receive incoming connections (i.e., not behind a NAT/Firewall)
- "**Workers**": Servers that cannot receive incoming connections

- Commands circulate the P2P network by passing commands between peers
  - Commands get passed to a worker once it reaches out

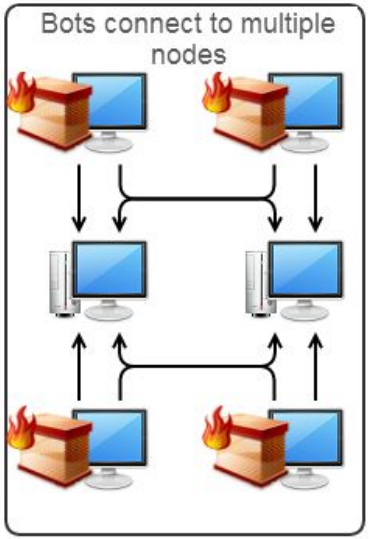
Peer2Peer Botnet Anatomy

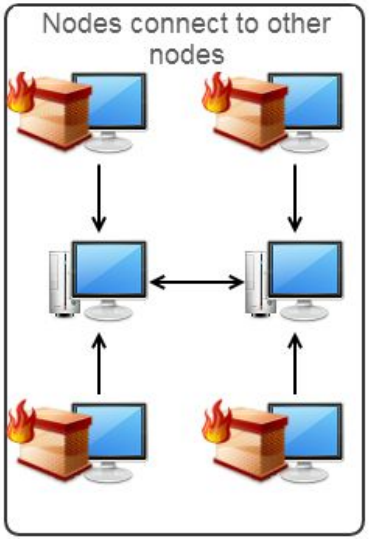




- When a worker joins the botnet it is given a list of IP addresses (peers) to connect to.
  - Long list of candidates ensures that all peers need to be taken down for new bots to join
- If all peers get taken down...existing bots may continue to carry out existing attack

Dismantling P2P Botnets





- Need to introduce many “deceptive” peers into the network
  - Introduce by advertise the peer as a new “infected” peer
  - “deceptive” : peers with the intention of taking down the botnet)
- Have the peers provide workers with peer IP addresses that only belong to “deceptive” peers
- “Deceptive” peers/workers will soon become a majority of the network
- At some point, use “deceptive” network to tell workers to stop

Mozi Botnet

- Peer-to-Peer botnet
- Discovered in 2019 and supposedly has > 1.5 million peers (majority in China)
- Uses the Distributed Hash Table (DHT) protocol (i.e., Bittorrent protocol)
- Mostly infects Netgear, D-Link and Huawei routers -> Microsoft shared that botnet can perform MitM and spoofing attacks
- July 2021: Mozi botnet authors arrested by Chinese law enforcement
- August-September 2023: Sudden drop in botnet activity and activation of botnet “kill switch”
- Nobody claimed credit for takedown

Worms (WannaCry)

Bureau 121

- A group within the North Korean General Bureau of Reconnaissance that is in charge of cyber warfare
- UN 2019 reported that North Korea raised > $2 billion from hacking (and spends the $ on nuclear missile development)
- North Korea generally denies involvement
- Affiliated with Lazarus group (also from North Korea)
- U.S Justice Department indicted 3 men from this group for:
  - 2014 hack of Sony Pictures
  - the global “WannaCry ransomware contagion” of 2017
  - the theft of roughly $200 million and attempted theft of more than $1.2 billion from banks and other victims worldwide.

WannaCry / WannaCrypt Attack

- The NSA developed an exploit (“EternalBlue”) and a backdoor tool (“DoublePulsar”) that both target Microsoft SMB (port 445)
  - SMB “Server Message Block” protocol allows users to access files on remote servers
  - Exploit/backdoor sends specially crafted packets using SMB to allow for remote code execution on server

WannaCry / WannaCrypt Attack

- The NSA developed an exploit (“EternalBlue”) and a backdoor tool (“DoublePulsar”) that both target Microsoft SMB (port 445)
  - SMB “Server Message Block” protocol allows users to access files on remote servers
  - Exploit/backdoor sends specially crafted packets using SMB to allow for remote code execution on server

- Exploit/Backdoor leaked by “The Shadow Brokers” hacker group
  - Microsoft releases patches (Microsoft was unaware that vulnerabilities had even existed before..)...but not all organizations update in time

WannaCry / WannaCrypt Attack

- The NSA developed an exploit (“EternalBlue”) and a backdoor tool (“DoublePulsar”) that both target Microsoft SMB (port 445)
  - SMB “Server Message Block” protocol allows users to access files on remote servers
  - Exploit/backdoor sends specially crafted packets using SMB to allow for remote code execution on server

- Exploit/Backdoor leaked by “The Shadow Brokers” hacker group
  - Microsoft releases patches (Microsoft was unaware that vulnerabilities had even existed before..)...but not all organizations update in time

- Bureau 121 uses EternalBlue and DoublePulsar to build a ransomware attack (WannaCry)

WannaCry / WannaCrypt Attack

- Upon Infection, WannaCry will:
  - (1) Encrypt all the content + demands a ransom
  - (2) Scan for other vulnerable targets (within internal network and external network) to replicate infection

WannaCry / WannaCrypt Attack

- Upon Infection, WannaCry will:
  - (1) Encrypt all the content + demands a ransom
  - (2) Scan for other vulnerable targets (within internal network and external network) to replicate infection
    - If target already has DoublePulsar (creates a back door and allows for root execution of code):
      - Infect machine with WannaCry.
    - If target is vulnerable to EternalBlue:
      - use EternalBlue to deliver DoublePulsar
      - Use DoublePulsar to infects the machine with WannaCry

WannaCry / WannaCrypt Attack

- Within a day the code was reported to have infected more than 230,000 computers in over 150 countries
- ~70K devices (computers, MRI scanners, blood-storage refrigerators) in England's National Health Service were estimated to be affected and some non-critical emergencies and ambulances were diverted

HSR Health Services Research

RESEARCH ARTICLE

Data breach remediation efforts and their implications for hospital quality

Sung J. Choi PhD, M. Eric Johnson PhD, Christoph U. Lehmann MD,

First published: 10 September 2019 | https://doi.org/10.1111/1475-6773.13203 | Citations: 7

Principal Findings

Hospital time-to-electrocardiogram increased as much as 2.7 minutes and 30-day acute myocardial infarction mortality increased as much as 0.36 percentage points during the 3-year window following a breach.

How to Accidentally Stop a Global Cyber Attacks

By : MalwareTech May 13, 2017 Category : Personal Stories Tags: ms17-010, ransowmare, stories, WannaCry

- WannaCry gets “accidentally” stopped because Marcus Hutchins---a free-lance(ish) security geek---began reverse-engineering the code and noticed a domain
- Domain was unregistered and it turned out to be a baked in “kill-switch” with the following logic
    - If: domain is unregistered, continue with infection
    - Else: stop the encryption/infection
- Marcus quickly registered the domain name and the infection stopped (and for the most part doesn’t reach the US)

```
qmemcpy(&szUrl, sinkholeddomain, 0x39u);      // previously unregistered domain, now sinkholed
v8 = 0;
v9 = 0;
v10 = 0;
v11 = 0;
v12 = 0;
v13 = 0;
v14 = 0;
v4 = InternetOpenA(0, 1u, 0, 0, 0);
v5 = InternetOpenUrlA(v4, &szUrl, 0, 0, 0x84000000, 0);// do HTTP request to previously unregistered domain
if ( v5 )                                     // if request successful quit
{
  InternetCloseHandle(v4);
  InternetCloseHandle(v5);
  result = 0;
}
else                                          // if request fails, execute payload
{
  InternetCloseHandle(v4);
  InternetCloseHandle(0);
  detonate();
  result = 0;
}
return result;
}
```